

BML Switch — API Guide for AppInSnap

AppInSnap API Guide — BML Integration Switch (Phase 0 Sandbox)

Audience: AppInSnap mobile engineers

Product: Bank Al Murqarmah Integration Switch (AppInSnap → Switch → Mock iMAL)

Version: Phase 0 / 0.1.0-SNAPSHOT

Sandbox Base URL: `http://46.224.146.158:18080`

Host / IP: 46.224.146.158

Port: 18080

Local Docker (optional): `http://localhost:8080`

Related	Link
Test data sheet	APPINSNAP-TEST-DATA.md
Postman how-to	APPINSNAP-POSTMAN-GUIDE.md
Collection	BML-Switch-Phase0.postman_collection.json
OpenAPI	../openapi/assanpay-switch-v1.yaml
Live Swagger	http://46.224.146.158:18080/swagger-ui.html
Smoke script	./scripts/smoke.sh

Mock OTP is always 1234 in this sandbox.

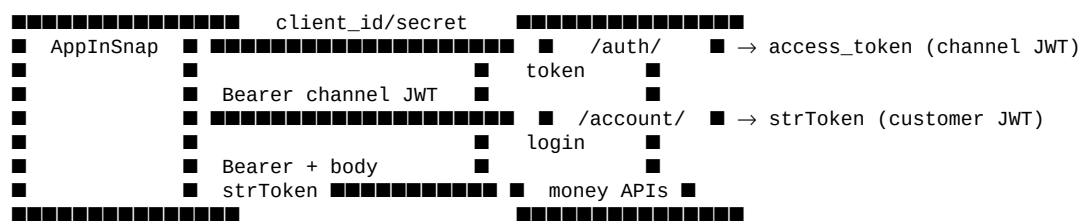
1. What this Switch is

The Switch is the **only backend** AppInSnap talks to for banking operations. It:

- Authenticates the **channel** (your app) with a short-lived JWT
- Authenticates the **customer** with `strToken` from login
- Serves **lookups** (banks, purpose codes, ...) so the app never hardcodes IMDs
- Proxies inquiry / IFT / IBFT to iMAL (mock in sandbox)
- Preserves AssanPay-compatible JSON shapes AppInSnap already expects

There is **no AppInSnap-facing frontend** — this is a REST API only.

2. Auth model (dual)



Token	Where it goes	Lifetime
Channel access_token	Header Authorization: Bearer ...	15 min (expires_in: 900)
Channel refresh_token	Body of /auth/refresh	7 days

Customer strToken	JSON body field strToken (required on customer APIs)	Same order as access (~15 min)
-------------------	---	--------------------------------

Optional alias: header X-Str-Token if body omits strToken. **Never** put strToken in Authorization.

2.1 Channel token

POST /api/v1/auth/token — **no Bearer required**

```
{
  "client_id": "appinsnap-sandbox",
  "client_secret": "change_me_sandbox_secret",
  "grant_type": "client_credentials"
}
```

Success (200):

```
{
  "access_token": "<jwt>",
  "token_type": "Bearer",
  "expires_in": 900,
  "refresh_token": "<opaque>",
  "refresh_expires_in": 604800,
  "correlationId": "a1b2c3d4-e5f6-7890-abcd-ef1234567890"
}
```

Refresh: POST /api/v1/auth/refresh with { "refresh_token": "..." } — same response shape; old refresh is revoked.

Channel auth failure: HTTP **401** (problem JSON), e.g. detail: CHANNEL_TOKEN_EXPIRED.

2.2 Customer login → strToken

POST /api/v1/account/login — requires channel Bearer

```
{
  "UserName": "ali.khan",
  "CNIC": "4210112345678",
  "password": "Sandbox@123"
}
```

Success (200):

```
{
  "Response_Code": "00",
  "Response_Desc": "Success",
  "strToken": "<customer-jwt>",
  "UserName": "ali.khan",
  "correlationId": "..."
}
```

2.3 Standard headers on protected calls

```
Authorization: Bearer <access_token>
Content-Type: application/json
X-Correlation-Id: <uuid>           # optional; Switch mints if absent
Idempotency-Key: <uuid>           # required on IFT, IBFT, account/open
```

3. AssanPay response shape quirks (must parse correctly)

API	Nesting / casing	Notes
Balance	Capital Return	Return.Amount, Return.FromAccount, ...
IFT payment	Lowercase return	Nested object + top-level Response_Code

IBFT payment	Flat	stan, transactionID, fee at root — no return
IBFT title	Double nest	IBFTTitleFetchResponse.return...
Fee	Always "0.00" in mock	No separate fee API

Always check **HTTP status first**, then Response_Code when HTTP is 200. Auth failures are **401**, not soft 00.

4. Happy-path flows

4.1 Login → Balance → IFT

1. POST /auth/token → access_token
2. GET /lookups/banks (cache for later IBFT)
3. POST /account/login → strToken
4. POST /inquiry/balance (fromAccount=0345001234567)
5. POST /payment/ift with new Idempotency-Key → nested return.status=00

4.2 IBFT (with OTP ¹²³⁴)

1. Channel token + login (as above)
2. GET /lookups/banks → pick imd (e.g. 601004)
3. POST /inquiry/ibft-title with toIMD / toIBAN / toAccount
4. POST /auth/otp/send → otpReference
5. POST /auth/otp/verify with "otp": "1234" → otpTicket
6. POST /payment/ibft with otpTicket + Idempotency-Key → flat success + fee: "0.00"
7. Poll POST /inquiry/ibft-status until status=POSTED (sandbox is immediate)

4.3 Onboarding Path A (even CNIC — auto)

1. Channel token + lookups (occupations, purpose-of-account, provinces, ...)
2. Login (or register after open)
3. Upload / validate / liveliness / fingers (mock success for even CNIC)
4. POST /account/open + Idempotency-Key → accountNumber + IBAN
5. Register credentials if needed → login

4.4 Onboarding Path B (odd CNIC — manual)

1. Same KYC steps; odd last digit → open returns Response_Code 79
2. Sandbox only: POST /account/approve-mock with CNIC
3. Retry account/open

5. Test data (sandbox)

Full sheet: APPINSNAP-TEST-DATA.md

Item	Value
client_id / secret	appinsnap-sandbox / change_me_sandbox_secret
User / password	ali.khan / Sandbox@123
CNIC (even)	4210112345678
CNIC (odd / review)	4210112345679
From account	0345001234567 (150000 PKR)

IFT to	0345001234568 (50000 PKR)
Zero	0345009999999
Invalid	0345000000000
Mock OTP	1234
Sample IBFT IMD	601004 (Meezan)
Sample toIBAN	PK12MEZN0000001234567890

6. Field ownership

Owns	Examples
Mobile sends	strToken, amounts, accounts, CNIC, toIMD/toIBAN, OTP, PurposeOfPayment, Idempotency-Key, login password
Switch injects / overwrites	Bank IMD of own bank, agent account, channelId, MCC, merchant name, app id, delimiter, net id — do not trust client overrides
Switch generates if blank	stan / intSTAN, dates/times, correlationId

Amount format: string, 2 decimals, no commas → "100.00".

7. Endpoint catalog

Auth legend: **Public** | **Channel** (Bearer) | **Channel + strToken**

7.1 System

GET /api/v1/system/health — Public

Success:

```
{
  "status": "UP",
  "mockImal": true,
  "mockOtp": true,
  "db": "UP",
  "correlationId": "..."
```

GET /api/v1/system/version — Channel

Returns appVersion, catalogVersion, mockImal, correlationId.

7.2 Auth

POST /api/v1/auth/token — Public

See §2.1. Errors: HTTP 401 invalid client.

POST /api/v1/auth/refresh — Public

```
{ "refresh_token": "<refresh_token>" }
```

POST /api/v1/auth/logout — Channel

```
{
  "refresh_token": "<optional>",
  "strToken": "<optional>,"
```

```

    "revokeCustomerSession": true
  }

```

Success: { "Response_Code": "00", "Response_Desc": "Success", "correlationId": "..."} }

POST /api/v1/auth/otp/send — Channel + strToken

```

{
  "strToken": "<customer-jwt>",
  "purpose": "IBFT",
  "mobile": "03001234567"
}

```

Success:

```

{
  "Response_Code": "00",
  "Response_Desc": "Success",
  "otpReference": "OTP-MOCK-A1B2C3D4",
  "expires_in": 120,
  "correlationId": "..."}

```

POST /api/v1/auth/otp/verify — Channel + strToken

```

{
  "strToken": "<customer-jwt>",
  "otpReference": "OTP-MOCK-A1B2C3D4",
  "otp": "1234"
}

```

Success:

```

{
  "Response_Code": "00",
  "Response_Desc": "Success",
  "otpTicket": "TICKET-...",
  "correlationId": "..."}

```

Common error (200): Response_Code 78 — wrong OTP / expired reference.

7.3 Lookups — Channel only

All return envelope:

```

{
  "correlationId": "...",
  "catalogVersion": 3,
  "asOf": "2026-09-28T...",
  "items": [ ... ],
  "Response_Code": "00",
  "Response_Desc": "Success"
}

```

Method	Path	Notes
GET	/api/v1/lookups/banks?active=true&supportsIbft=true	Required before IBFT UI — ≥16 banks
GET	/api/v1/lookups/banks/{imd}	Single bank; 404 if unknown
GET	/api/v1/lookups/purpose-of-payment	Alias: /purpose-codes
GET	/api/v1/lookups/purpose-of-account	
GET	/api/v1/lookups/occupations	
GET	/api/v1/lookups/response-codes	
GET	/api/v1/lookups/account-types	
GET	/api/v1/lookups/provinces	
GET	/api/v1/lookups/id-types	

GET	/api/v1/lookups/finger-indexes	
GET	/api/v1/lookups/onboarding-steps	
GET	/api/v1/lookups/branches	
GET	/api/v1/lookups/currencies	
GET	/api/v1/lookups/app-config	Public config map
GET	/api/v1/lookups/version	Catalog version

Sample bank item:

```
{
  "imd": "601004",
  "bankCode": "MEZN",
  "bankShortName": "Meezan",
  "bankName": "Meezan Bank Limited",
  "ibanBankCode": "MEZN",
  "supportsIbft": true,
  "isActive": true,
  "sortOrder": 40
}
```

Honor ETag / If-None-Match (304). **Do not hardcode bank lists in the app.**

7.4 Account / onboarding — Channel (+ strToken where noted)

POST /api/v1/account/login — Channel

See §2.2. Bad password → 14. Lockout → HTTP 401 + 75.

POST /api/v1/account/register — Channel

```
{
  "CNIC": "4210112345678",
  "AccountNo": "0345001234567",
  "MobileNo": "03001234567",
  "UserName": "ali.khan",
  "password": "Sandbox@123"
}
```

POST /api/v1/account/customer-detail — Channel + strToken

```
{ "strToken": "...", "CNIC": "4210112345678" }
```

Success nest: Response.CNIC, FULL_NAME, Email, ADDRESS, MOBILE_NUM, D_Birth.

POST /api/v1/account/account-list — Channel + strToken

```
{
  "strToken": "...",
  "Request": { "CNIC": "4210112345678" }
}
```

Success: Response.CASA_Account_List[] with Account_Number, Account_IBAN, Account_Title, ...

POST /api/v1/account/open — Channel + strToken + Idempotency-Key

```
{
  "strToken": "...",
  "CNIC": "4210112345678",
  "fullName": "ALI KHAN",
  "MobileNo": "03001234567",
  "occupationCode": "EMP",
  "purposeOfAccountCode": "SAV",
  "productCode": "ASAAN_DIGITAL"
}
```

Success:

```
{
  "Response_Code": "00",

```

```

    "Response_Desc": "Success",
    "accountNumber": "0345...",
    "IBAN": "PK00BMAL...",
    "accountTitle": "ALI KHAN",
    "currency": "PKR",
    "productCode": "ASAAN_DIGITAL",
    "status": "ACTIVE",
    "correlationId": "..."
  }

```

Odd CNIC without approve: 79 Manual review pending.

KYC mocks (Channel + strToken)

Path	Role
POST /account/upload-documents-unikrew	OCR + face confidence (even CNIC high)
POST /account/validate-document-unikrew	Doc authenticity mock
POST /account/verify-liveliness	Liveness mock
POST /account/verify-fingers	Biometric mock

POST /api/v1/account/approve-mock — Channel (sandbox only)

```

{ "CNIC": "4210112345679" }

```

POST /api/v1/account/change-password — Channel + strToken

```

{
  "strToken": "...",
  "currentPassword": "Sandbox@123",
  "newPassword": "Sandbox@456"
}

```

POST /api/v1/account/reset-password-mock — Channel (sandbox)

```

{ "CNIC": "4210112345678", "newPassword": "Sandbox@123" }

```

POST /api/v1/accounts/information — Channel + strToken

```

{ "strToken": "...", "fromAccount": "0345001234567" }

```

7.5 Payments — Channel + strToken + Idempotency-Key

POST /api/v1/payment/ift

```

{
  "strToken": "...",
  "fromAccount": "0345001234567",
  "toAccount": "0345001234568",
  "amount": "100.00",
  "PurposeOfPayment": "FAM",
  "Description": "smoke ift"
}

```

Success (nested return):

```

{
  "return": {
    "agentAccount": "00000000000",
    "amount": "100.00",
    "channelId": "MOBILE",
    "fromAccount": "0345001234567",
    "toAccount": "0345001234568",
    "stan": "123456",
    "status": "00",
    "statusDescription": "Success",
    "PurposeOfPayment": "FAM"
  },
  "Response_Code": "00",
  "Response_Desc": "Success",
  "correlationId": "..."
}

```

Common errors (HTTP 200): 51 NSF · 12/14 bad account · 61 daily limit · missing Idempotency-Key → 30.

POST /api/v1/payment/ibft

```
{
  "strToken": "...",
  "fromAccount": "0345001234567",
  "toIMD": "601004",
  "toIBAN": "PK12MEZN0000001234567890",
  "toAccount": "1234567890",
  "amount": "25.00",
  "PurposeOfPayment": "FAM",
  "Description": "smoke ibft",
  "otpTicket": "TICKET-..."
}
```

Success (flat):

```
{
  "Response_Code": "00",
  "Response_Desc": "Success",
  "stan": "654321",
  "transactionID": "TXN-0F753F3E-6B0",
  "fee": "0.00",
  "correlationId": "..."
}
```

Common errors: 78 OTP · 76 bad IMD · 51 NSF · 61 limit.

7.6 Inquiry — Channel + strToken

POST /api/v1/inquiry/balance

```
{ "strToken": "...", "fromAccount": "0345001234567" }
```

Success (capital Return):

```
{
  "Return": {
    "Amount": "150000.00",
    "BranchCode": "001",
    "FromAccount": "0345001234567",
    "CURRENCY_CODE": "PKR"
  },
  "Response_Code": "00",
  "Response_Desc": "Success",
  "correlationId": "..."
}
```

POST /api/v1/inquiry/ift-title

```
{ "strToken": "...", "Account": "0345001234568" }
```

Success: nested lowercase return with accountTitle, account, status, ...

POST /api/v1/inquiry/ibft-title

```
{
  "strToken": "...",
  "fromAccount": "0345001234567",
  "toIMD": "601004",
  "toIBAN": "PK12MEZN0000001234567890",
  "toAccount": "1234567890",
  "amount": "25.00"
}
```

Success (double nest):

```
{
  "IBFTTitleFetchResponse": {
    "return": {
      "accountTitle": "ALI KHAN",
      "toIBAN": "PK12MEZN0000001234567890",
      "toIMD": "601004",

```

```

        "toAccount": "1234567890",
        "fromAccount": "0345001234567",
        "amount": "25.00"
    }
},
"Response_Code": "00",
"Response_Desc": "Success",
"correlationId": "..."
}

```

POST /api/v1/inquiry/cnic

```
{ "strToken": "...", "CNIC": "4210112345678" }
```

Success: Res.GetAccountFromCNICItems.Item (object or array).

POST /api/v1/inquiry/ibft-status

```

{
  "strToken": "...",
  "transactionID": "TXN-...",
  "stan": "654321"
}

```

Success: Response_Code=00, status=POSTED, fee=0.00, amount, ...

POST /api/v1/inquiry/mini-statement

```
{ "strToken": "...", "fromAccount": "0345001234567", "limit": 10 }
```

Success: transactions[] with bookingDate, narration, direction, amount, balanceAfter, stan.

POST /api/v1/inquiry/statement

```

{
  "strToken": "...",
  "fromAccount": "0345001234567",
  "fromDate": "2026-09-01",
  "toDate": "2026-09-28"
}

```

Max window 90 days; else 61.

POST /api/v1/inquiry/limits

```
{ "strToken": "...", "fromAccount": "0345001234567" }
```

Success: dailyDebitLimit, dailyDebitUsed, dailyDebitRemaining, maxBalance, currency.

POST /api/v1/inquiry/receipt

```

{
  "strToken": "...",
  "stan": "654321",
  "transactionID": "TXN-..."
}

```

8. Error handling (quick)

Kind	HTTP	What to branch on
Channel / session / lockout	401	problem detail or Response_Code 91 / 75
Validation	400	Response_Code 30 + fieldErrors
Business (NSF, OTP, IMD, ...)	200	Response_Code (51, 78, 76, 14, 61, 79, ...)
Upstream / fault	5xx / 99	Retry with same Idempotency-Key for money APIs

Selected codes:

Code	Meaning
00	Success
12	Invalid / closed account
14	Not found / bad credentials
30	Validation
51	Insufficient funds
61	Limit exceeded
75	Lockout
76	Invalid / inactive IMD
77	KYC incomplete
78	OTP required or invalid
79	Manual review pending
91	Session expired / missing strToken

Full detail: error-handling.md.

9. Rate limits & lockout

Control	Behavior
Login lockout	5 failed passwords → HTTP 401 + 75; ~30 min lock
Idempotency	Required on IFT/IBFT/open; replay within ~24h returns cached body
Lookups cache	Honor Cache-Control / ETag (sandbox ~300s)

10. Bring-up & verification

Sandbox (shared with ApplnSnap):

```
curl -s http://46.224.146.158:18080/api/v1/system/health  
# expect: "status":"UP"
```

Base URL: `http://46.224.146.158:18080` · Swagger: `http://46.224.146.158:18080/swagger-ui.html`

Import Postman collection (BML-Switch-Phase0.postman_collection.json) — `baseUrl` is already set to the sandbox IP/port — then run folder **01** — **Happy path**.

Local Docker (optional for Switch team):

```
cp .env.example .env  
docker compose up --build -d  
curl -s http://localhost:8080/api/v1/system/health  
BASE=http://localhost:8080 ./scripts/smoke.sh
```

11. Support contacts

Questions on contract drift or sandbox access: Bank Al Murqamah Switch team (via your project liaison).

Include `correlationId` from the failing response in every ticket.